

PRIVACY REPORT

개인정보 이슈 심층분석

AI와 프라이버시

PRIVACY REPORT

2025년
개인정보 이슈
심층분석

CONTENTS

1

AI 에이전트 환경에서의 개인정보 보호

2

EU AI Act와 GDPR간의 관계

3

AI 시대 신기술 · 신산업 혁신 촉진을 위한
개인정보 규율체계 정비 방향

AI 에이전트 환경에서의 개인정보 보호

김병필

KAIST 기술경영전문대학원 | 교수/변호사

1. LLM 기반 에이전트 환경과 개인정보의 흐름

■ LLM(Large Language Model) 기술이 급속히 발전하면서, 이용자와 지속적으로 상호작용하며 상황에 따라 작업을 수행하는 ‘AI 에이전트(AI agent)’의 도입이 빠르게 확산되고 있다. 이러한 AI 에이전트는 단순히 이용자의 질의에 응답하는 수준을 넘어, 장기적인 대화 맥락을 기억하고, 이용자의 앱, 일정, 이메일 등 다양한 시스템과 연동되며, 개인화된 작업을 수행하는 방향으로 진화하고 있다.¹⁾

이 글은 이러한 변화에 대응하여, AI 에이전트의 기술적 구조와 동작 방식에서 파생되는 새로운 개인정보 침해 위험을 분석한다. AI 에이전트는 이용자 지시를 수행하는 과정에서 다양한 개인정보를 수집·처리·전달하게 되며, 그 처리 단계마다 고유의 프라이버시 리스크가 발생할 수 있다. AI 에이전트 환경하에서의 개인정보가 전달되는 일반적인 경로는 다음과 같이 요약할 수 있다.²⁾

① **이용자 입력 및 계획 단계.** 이용자가 챗봇이나 음성비서 등과 같은 자연어 기반 인터페이스를 통해 질의, 명령, 과업 지시 등을 입력한다. 예컨대 “여름휴가 여행을 위한 항공권과 호텔을 예약해 줘”와 같은 요청이 이에 해당한다. 이때, 이용자 장치에서 입력 정보를 표준화하거나, 고유식별정보를 마스킹하는 등의 로컬 전처리 과정이 수행될 수 있다. 이후 해당 요청은 LLM을 통해 해석되며, AI 에이전트는 요청의 의미를 분석하고, 목표 달성을 위해 어떤 외부 애플리케이션을 호출하고 어떤 요청을 보낼지를 스스로 계획한다.

② **외부 애플리케이션과의 상호작용 단계.** AI 에이전트는 외부 정보를 얻거나, 기능을 수행하기 위하여 외부 시스템(예: 항공편 예약 API 등)에 접속하여 이용자 요구사항(예: 여행 일정, 선호 항공사 등)을 기반으로 요청을 전송한다. 이후 외부 시스템의 응답을 수신하여, 업무 흐름에 맞추어 후속 작업에 통합한다. 이러한 상호작용은 다수의 외부 시스템과 연속적으로 이루어질 수 있고, 앞서 수집된 정보가 후속 요청의 입력으로 활용되기도 한다. (예: 항공편 조회 결과를 바탕으로 호텔 검색)

1) EDPB, AI Privacy Risks & Mitigations – Large Language Models (LLMs) (2025.) p. 37.

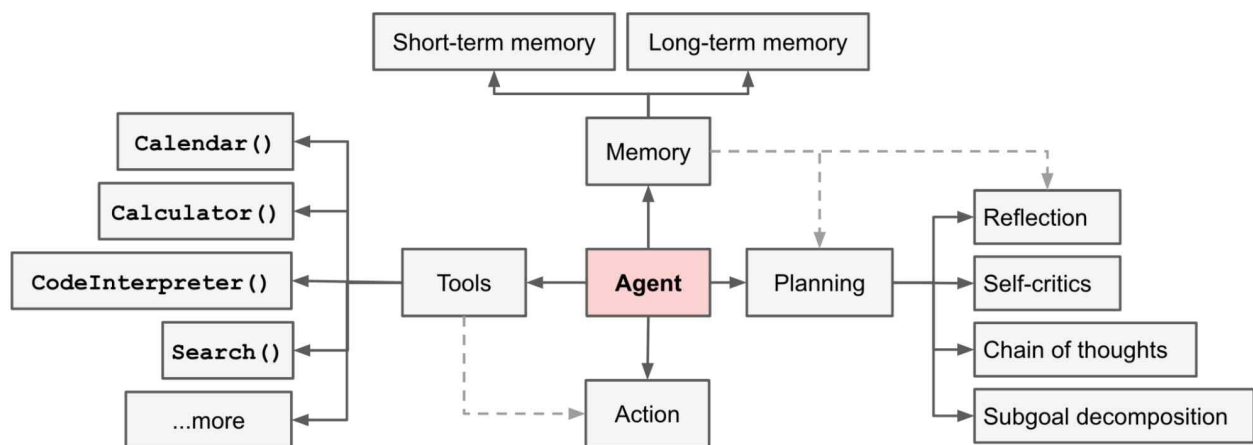
2) EDPB, AI Privacy Risks & Mitigations – Large Language Models (LLMs) (2025.) p. 38.

③ **응답 결과의 통합·정리 및 결과 출력.** AI 에이전트는 외부 애플리케이션으로부터 받은 응답을 통합·정리하여 최종 결과를 구성한다. 예컨대, 항공권과 호텔 정보를 종합해 하나의 예약 제안을 만들고, 그 과정에서 여러 응답 간의 일관성을 점검하고, 충돌이나 중복과 같은 오류 요소를 탐지하고 조정할 수 있다. 이후 통합된 결과는 이용자 인터페이스를 통해 이용자에게 제공되며, 필요시 후속 질의를 통해 이용자의 의도를 재확인하거나, 조건을 조정하도록 안내할 수 있다.

④ **이용자 상호작용 로그 저장 및 활용.** 일부 AI 에이전트는 이용자와의 상호작용 로그를 저장하여 시스템 성능 개선, 오류 진단, 이용자 경험 향상 등을 위한 자료로 활용할 수 있다. 이러한 로그는 에이전트의 재학습이나 파인튜닝을 위해 사용될 수도 있다. 다만 로그 저장 및 활용은 개인정보 보호법령 및 개인정보 처리방침에 따라 이루어져야 하고, 적절한 익명처리·가명처리와 접근 통제와 같은 기술적 조치가 필요할 수 있다.

아래 그림에서 보는 바와 같이 AI 에이전트의 핵심적 역량은 계획 및 추론, 메모리, 도구 활용의 세 가지로 구분할 수 있다. 이 세 가지 역량은 AI 에이전트가 복합적인 과제를 자율적으로 수행하고, 이용자와의 상호작용을 통해 지속적으로 학습·개선되도록 하는 데 필수적인 요소들이다.³⁾ 이하에서는 이러한 핵심 역량 각각이 야기할 수 있는 개인정보 침해 위험을 구체적으로 검토한다.

그림1 1. LLM 기반 자율 에이전트 시스템의 개요⁴⁾



2. ‘계획 및 추론’ 기능에 따른 개인정보 침해 위험

‘계획 및 추론(planning and reasoning)’은 AI 에이전트의 자율성을 가능하게 하는 핵심 기능

3) OWASP, Agentic AI – Threats and Mitigations (2025.02.) p. 4.

4) Lilian Weng, LLM Powered Autonomous Agents (2023.06.23.)

이다. AI 에이전트는 주어진 목표를 달성하기 위해 필요한 업무 흐름을 스스로 계획하고, 그 계획을 동적으로 조정하면서 복잡한 문제를 해결할 수 있다. 일반적으로 LLM이 이러한 추론 엔진으로 사용되며, 여기에는 과제를 단계별로 분석하는 '연쇄 사고(chain of thought)', 과거 행동을 반성하고 오류를 수정하는 '자기-반성(self-critique)' 등의 기법이 구현된다.⁵⁾

이러한 고도화된 추론 기능은 새로운 형태의 개인정보 침해 위험을 야기할 수 있다. 우선, LLM이 생성한 중간 결과 또는 결론에는 이용자로부터 명시적으로 제공받지 않은 성향, 행동 패턴, 심리 상태 등에 대한 암묵적 추론을 포함할 수 있다. 최근 연구는 LLM이 레딧(Reddit)의 게시글만으로 이용자의 위치, 소득, 성별과 같은 속성을 85%의 정확도로 추론할 수 있음을 보여주었다.⁶⁾ 이처럼 이용자 입력에서 포함되지 않은 정보라도, AI 에이전트의 추론 과정을 통해 의도치 않게 노출될 수 있다.

더욱이 이용자가 입력한 정보로부터 질병 등 민감정보나 재정 상태, 위치 정보 등과 같은 민감한 속성이 추론되어 이후 작업에 사용될 가능성도 존재한다. 가령 이용자가 특정 약물의 복용 시간에 알람을 해 달라고 지시한 경우, AI 에이전트는 해당 이용자가 특정 질병을 앓고 있을 가능성을 추론할 수 있다.⁷⁾ 이러한 과정을 거치면서 의도치 않게 이용자의 건강에 관한 정보가 저장될 뿐 아니라, 이후 추천이나 출력에 반영될 수 있다.

마지막으로, LLM 기반 추론은 설명가능성 측면에서 구조적 한계를 지닌다. 이용자 입장에서 AI의 추론 경로를 명확히 파악하거나 검증하기 어렵기 때문에, 잘못된 결론이나 편향된 응답을 생성되더라도 이를 확인하거나 반박하기 쉽지 않다. 많은 LLM은 여전히 '블랙박스'와 유사한 상태로, 이 문제는 시스템 전반에 대한 신뢰성과 책임성을 저해하고, 의사결정 지원 도구로서의 활용에도 중대한 제약이 될 수 있다.⁸⁾

3. '메모리' 기능에 따른 개인정보 침해 위험

AI 에이전트의 메모리 기능은 단기 메모리(short-term memory)와 장기 메모리(long-term memory)로 구분할 수 있다. 단기 메모리는 하나의 세션 혹은 대화 컨텍스트 창(context window) 내에서 유지되는 정보인 반면, 장기 메모리는 개별 세션을 넘어서 지속적이고 누적적으로 정보를 저장하여, 이용자의 과거 요청, 선호, 행동 이력 등을 축적하고, 이를 바탕으로 더욱 정교한

5) OWASP, Agentic AI - Threats and Mitigations (2025.02.) p. 5.

6) Robin Staab et al., Beyond Memorization: Violating Privacy via Inference with Large Language Models (2023.)

7) Kang Chen et al., A Survey on Privacy Risks and Protection in Large Language Models (2025.)

8) Haoyan Luo and Lucia Specia, From Understanding to Utilization: A Survey on Explainability for Large Language Models (2024.)

개인화를 구현하는 데 활용된다. 예컨대, AI 에이전트가 Retrieval-Augmented Generation(RAG) 구조를 통해 과거 이용자 데이터를 검색하고, 이를 LLM 프롬프트에 반영함으로써, 이전 대화 맥락을 반영한 응답을 생성할 수 있다.⁹⁾

그러나, 이러한 장기 메모리 기능은 프라이버시 침해의 새로운 위험을 야기할 수 있다. 첫째, 이용자 정보를 장기적으로 저장하고 재활용하는 과정에서, 개인정보가 정당한 권한 없이 이용되거나 정보주체의 기대와 달리 활용될 가능성이 높아진다.¹⁰⁾ 특히 장기간에 걸쳐 축적된 정보가 외부 공격이나 내부 유출로 인해 노출될 경우, 정보주체는 심각한 피해를 입을 수 있다. 최근 연구는 LLM 기반 에이전트의 메모리로부터 이용자와의 과거 상호작용 기록이 추출될 수 있음을 실험적으로 보여준 바 있다.¹¹⁾

둘째, 개인정보의 지속적 저장 및 재사용은 개인정보 보호법상의 “최소 수집 원칙”에 위배될 소지가 있다. 특히 애플(Apple), 구글(Google) 등 글로벌 빅테크 기업들은 개인의 캘린더, 이메일, 문서 등 개인 컨텍스트 데이터를 AI 에이전트에 통합하려는 시도를 본격화하고 있다.¹²⁾ 이러한 데이터의 활용은 통상 정보주체의 동의를 기반으로 하지만, 현실적으로 동의의 실효성은 제한적이며, 정보주체가 과도한 맥락 정보 수집에 대한 통제권을 행사하기 어려운 구조적인 한계가 존재한다. 나아가 이와 같은 장기 메모리 기반 개인화는 자동화된 분석 및 프로파일링을 심화시켜, 정보주체의 개인정보자기결정권을 제한하고 사생활을 침해할 우려가 제기된다.

셋째, 장기 메모리 기능은 단순히 개인화된 응답을 제공하는 것을 넘어, 이용자를 지속적으로 관찰·기록·분석할 수 있는 “감시 사회(surveillance society)”의 기술적 기반으로 기능할 위험이 있다. AI 에이전트는 이용자의 반복된 행동, 습관, 선호 등을 장기적으로 추적하여, 개인의 미래 행동을 예측하거나, 나아가 행동을 통제할 수 있는 구조적 환경을 조성할 수 있다.¹³⁾ 그 결과 AI 에이전트는 예상치 못한 감시자 역할로 기능하며, 개인의 행동과 표현을 위축시키는 ‘위축 효과(chilling effect)’를 발생시킬 수 있다.¹⁴⁾ 특히 기업 또는 국가가 AI 에이전트의 메모리 기능과 로그 기록을 감시 인프라로 활용할 경우, 프라이버시 침해는 물론 민주적 질서의 훼손으로 이어질 수 있다. 이에 따라 에이전트 메모리 기능이 감시 구조로 악용되지 않도록, 투명한 기록 관리와 감사 체계의 확보가 필요하다는 의견이 제시되고 있다.¹⁵⁾

9) Lilian Weng, LLM Powered Autonomous Agents (2023.06.23.)

10) EDPB, AI Privacy Risks & Mitigations – Large Language Models (LLMs) (2025.) p. 41.

11) Bo Wang et al., Unveiling Privacy Risks in LLM Agent Memory (2025.)

12) 순다 피차이(Sundar Pichai), 구글 I/O 2025: 이론이 현실이 되다, 구글코리아 블로그 (2025.05.20.)

13) Chad DeChant, Episodic Memory in AI Agents Poses Risks That Should Be Studied and Mitigated, 2025 IEEE Conference on Secure and Trustworthy Machine Learning (2025.)

14) Daragh Murray et al., The Chilling Effects of Surveillance and Human Rights: Insights from Qualitative Research in Uganda and Zimbabwe, Journal of Human Rights Practice (2024.)

15) Alan Chan et al., Visibility into AI Agents, Proceedings of the 2024 ACM Conference on Fairness, Accountability, and Transparency (2024.)

4. ‘도구 활용’ 기능에 따른 개인정보 침해 위험

■ 마지막으로, ‘도구 활용(action and tool use)’ 기능을 통해 AI 에이전트는 단순한 언어 이해를 넘어, 외부 시스템과 직접 상호작용할 수 있는 실행 역량을 갖추게 된다. 예컨대 웹 검색, 수치 계산, 코드 실행, 외부 API 호출 등 다양한 작업이 가능하며, 이를 통해 에이전트는 외부 서비스와 연동하여 이용자의 복합적 요청에 능동적으로 대응할 수 있다. 이러한 기능은 기존 챗봇과 구별되는 핵심적인 기술적 진보로 평가된다. 특히 앤트로픽(Anthropic)이 발표한 Model Context Protocol(MCP)은, AI 에이전트가 외부 애플리케이션과 맥락 정보를 실시간으로 교환할 수 있도록 설계되어, 이용자가 AI 에이전트를 통해 실행할 수 있는 작업의 범위를 크게 확장시켰다. 그러나, 이와 동시에 이러한 기능은 개인정보가 외부 애플리케이션으로 전송될 가능성을 증가시켜 새로운 프라이버시 위험을 초래할 수 있다.

무엇보다도, 외부 애플리케이션을 호출하는 과정에서 과도하거나 불필요한 개인정보나 민감정보가 그대로 전송될 수 있다는 점은 심각한 우려를 낳는다. 최근 한 연구는 지메일(Gmail), 슬랙(Slack), 노션(Notion), 페이스북(Facebook), 줌(Zoom) 등 다양한 협업 도구 환경에서 총 493건의 프라이버시 딜레마 상황을 구성하고, 최신 LLM 기반 에이전트의 프라이버시 규범 인식 및 적용 능력을 평가하였다.¹⁶⁾ 해당 연구에 따르면, 최신 모델(GPT-4 등)은 “해당 정보를 외부에 전달해도 되는가”라는 질문에 대해 비교적 높은 정확도로 응답하였으나, 행위(action) 기반 평가에서는 다른 결과가 나타났다. 즉, 실제 작업 수행 중에 민감정보가 외부 도구로 유출되는지를 측정한 결과, GPT-4는 25.68%의 높은 유출률을 보였다. 이는 LLM이 프라이버시 규범을 ‘인식’하고 있다 하더라도, 실제 함수 호출이나 API 연동과 같은 ‘행위’ 단계에서는 해당 규범을 적절히 적용하지 못하는 구조적 한계가 존재함을 보여준다.

또한 외부 애플리케이션에 개인정보를 전달하는 과정에서 있어서는 제3자 제공 또는 위탁 처리에 관한 법적 근거를 명확히 하고, 전달되는 개인정보의 범위를 엄격히 통제할 필요가 있다. 예컨대, 호텔 예약 업무를 수행하는 AI 에이전트가 MCP를 통해 호텔 API를 호출할 경우, 이용자의 위치나 과거 숙박 기록 등은 과도하고 불필요한 정보일 수 있다.

따라서, 도구 활용 기능의 안전한 구현을 위해서는 (1) 외부 시스템과의 연동 시 개인정보를 자동 필터링하는 기능을 내장하고, (2) 전송되는 정보의 최소화를 보장하며, (3) 연동 대상 시스템의 보안 수준 및 개인정보 처리방침을 검토하고, (4) 애플리케이션 호출 이력과 상호작용 로그를 투명하게 저장·관리할 필요가 크다. 이와 같은 안전조치는 AI 에이전트의 실행 능력 고도화와 개인정보 보호 간의 균형을 확보하기 위한 핵심적 조건이라 할 수 있다.

16) Yijia Shao et al., PrivacyLens: Evaluating Privacy Norm Awareness of Language Models in Action, Advances in Neural Information Processing Systems 37 (2024.)

참고 문헌 |

1. EDPB, AI Privacy Risks & Mitigations – Large Language Models (LLMs) (2025.)
2. OWASP, Agentic AI – Threats and Mitigations (2025.02.)
3. Lilian Weng, LLM Powered Autonomous Agents (2023.06.23.)
4. Robin Staab et al., Beyond Memorization: Violating Privacy via Inference with Large Language Models (2023.)
5. Bo Wang et al., Unveiling Privacy Risks in LLM Agent Memory (2025.)
6. 순다 피차이(Sundar Pichai), 구글 I/O 2025: 이론이 현실이 되다, 구글코리아 블로그 (2025.05.20.)
7. Chad DeChant, Episodic Memory in AI Agents Poses Risks That Should Be Studied and Mitigated, 2025 IEEE Conference on Secure and Trustworthy Machine Learning (2025.)
8. Daragh Murray et al., The Chilling Effects of Surveillance and Human Rights: Insights from Qualitative Research in Uganda and Zimbabwe, Journal of Human Rights Practice (2024.)
9. Alan Chan et al., Visibility into AI Agents, Proceedings of the 2024 ACM Conference on Fairness, Accountability, and Transparency (2024.)
10. Yijia Shao et al., PrivacyLens: Evaluating Privacy Norm Awareness of Language Models in Action, Advances in Neural Information Processing Systems 37 (2024.)

EU AI Act와 GDPR간의 관계

강지원

김·장 법률사무소 | 미국변호사(뉴욕주)

1. 들어가며

인공지능 서비스를 개발·제공하는 생애주기 전 과정은 데이터와 직결되어 있기에, 개인정보의 보호는 인공지능 서비스를 내부적으로 활용하거나 대고객 목적으로 제공하는 기업 모두가 직면한 중요한 현안이다. 특히 강도 높은 개인정보 보호 법제를 보유하고 있는 EU와 우리나라가 최근 세계에서 처음과 두 번째로 인공지능 규제법을 선제적으로 제정함으로써, 향후 규제당국이 다른 어느 국가도 “가지 않은 길”을 걷게 되었다는 점은 기업 입장에서 시사하는 바가 크다. 우리나라 개인정보 보호법과 인공지능 기본법은 앞서 오랜 입법 논의를 거쳐 제정된 EU의 법제를 적지 않은 부분 참고하여 만들어졌기에, EU AI Act와 EU 일반 개인정보 보호법(General Data Protection Regulation, “GDPR”)이 인공지능 서비스의 개발 및 제공 과정에서 어떻게 유기적으로 적용되어 기업의 개인정보 보호 업무에 영향을 주게 될지는 우리나라 기업과 규제당국 모두 예의 주시해야 될 부분이다.

AI Act는 두 법이 상충되는 부분에 있어 GDPR이 우선으로 적용되며, AI Act가 GDPR의 적용과 집행을 저해하지 않도록 해석되어야 한다는 점을 명시하고 있어 이론적으로는 인공지능의 규율과 개인정보의 보호가 서로 충돌하지 않는 것처럼 보인다, 그러나 실무적으로는 동일한 인공지능 서비스에 대해 두 법의 적용이 일도양단으로 명확하게 구분되지 않는 중첩 또는 모호성의 영역이 나타날 수 있기에, 기업 입장에서는 보다 면밀한 검토가 요구된다¹⁾. 인공지능이 제공하는 자동화된 결정에 대한 정보주체(또는 이용자)의 권리 보장, 인공지능이 도출한 결과물에 대한 설명 방안의 수립, 두 법에서 각각 요구하는 영향평가의 공통점과 차이점이 그 대표적인 영역이 될 수 있을 것으로 보인다.²⁾ 또한 2025.08.02.까지로 예정된 EU 회원국들의 AI Act 국내 집행기관 지정 결과 역시 개인정보 보호 정책과 인공지능 규제 정책 간의 균형에 영향을 미치는 요인이 될 수 있을 것이다.

2. 자동화된 결정으로부터 이용자를 보호하기 위한 안전장치

데이터 학습과 추론을 통해 인공지능이 내리는 판단은 GDPR상 자동화된 결정(automated

1) 이진규, 인공지능 프라이버시 침해위험 증가에 따른 국내외 관련 규범 (2024.01.) p.12.

2) Osborne Clarke, Interplay of the EU AI Act and GDPR (2025.03.25.)

decision-making, “ADM”)의 성격을 가지고 있다. 따라서 의료영상의 판독, 신용등급 평가, 생체 정보 기반 개인 식별(biometric identification) 등 판단 또는 판별이 관여되는 인공지능 서비스에 대해서는 AI Act 뿐 아니라 GDPR이 함께 적용될 수 있다. 그런데 GDPR에 따른 ‘자동화된 결정’이 항상 AI Act의 적용대상인 ‘AI 시스템’에 해당되는 것은 아니고, 역으로 AI 시스템 중 고위험 AI 시스템에 해당되는 일부 영역에 한해 인간의 관리·감독(human oversight) 등 이용자 보호를 위한 조치 의무가 요구되기 때문에, 두 법의 중첩 관계는 개별 인공지능 서비스의 성격에 따라 사안 별로 달라지게 된다.

먼저 인간의 개입 여부와 관련하여 두 법간 차이점을 좀 더 구체적으로 살펴보면, GDPR에 따른 ADM은 인간의 개입 없이 기술적 수단에 의해 완전히 자동화된 절차를 의미하며, 다만 ADM이 정보주체에게 “법률적 효과 또는 이와 유사한 수준의 중대한 영향을 미치는 결정”을 내릴 경우 ADM을 거부하고 그 판단 과정이나 재결정에 인간의 개입을 요구할 수 있는 선택권을 갖게 된다. 이에 반해, 신용등급 평가 등 앞서 예시로 든 인공지능 서비스는 AI Act상 고위험 AI 시스템 범주로서 인간의 관리·감독이 필수적으로 요구되기에, 개념상 인공지능에 의해 완전히 자동화된 결정이 내려지지 않는다는 차이점이 있다.³⁾ 한편 고위험 AI 시스템은 그 요건상 “건강·안전·기본권에 중대한 영향”을 미치면서 동시에 “의사결정에 중대한 영향”을 미쳐야 하기 때문에, 인간의 개입을 요구할 수 있는 (중대한 의사결정을 내리는) ADM과는 그 범위가 일정 부분 겹칠 수 있을 것이다. 반면 ADM은 AI Act상 AI 시스템의 핵심 개념인 “데이터 학습에 기반한 추론(inference) 능력”을 전제하지 않는다는 점에서 중요한 차이점을 나타낸다. 정보 처리에 따른 의사결정이 자동화된 절차에 따라 이루어지기만 하면 ADM에 해당될 수 있기 때문에, 인간이 사전에 입력한 코딩 작업에 따라 기계적으로 결과를 도출하는 규칙 기반 시스템(rule-based systems) 역시 ADM의 범주에 포함된다. 이러한 규칙 기반 시스템은 데이터 학습과 추론에 따른 결과물 산출을 수반하지 않아 AI 시스템에 해당되지 않으며, AI Act의 적용대상이 아니기에 인간의 관리·감독 역시 의무사항이 아니다.

다음으로 정보주체 또는 이용자가 누릴 수 있는 권리와 관련해, GDPR은 정보주체의 권리를 명시하는 접근 방식을 취하는 반면 AI Act는 후술할 설명받을 권리를 제외하면 이용자의 권리를 직접 명시하기 보다는 고위험 AI 시스템 제공자가 조치해야 할 준수사항을 규정하는 방식이라는 점에서 구분된다. 정보주체는 ADM에 대해 인간의 개입을 요구할 권리 뿐 아니라, 그 의사결정에 대해 자신의 견해를 표현하고 설명을 요구하며 이의를 제기할 권리를 보장받는다. 이와 대조적으로, 고위험 AI 시스템의 이용으로 영향 받는 자(affected persons)는 인공지능 서비스의 결과물에 대한 설명받을 권리를 보장 받고 해당 AI 시스템의 개발 및 서비스 운영 과정에서 인간의 관리·감독 조치가 따르게 되지만, 그 결과물 자체에 대해 자신의 의견을 개진하고 더 나아가 이의를 제기할 절차를 권리로서 보장받지는 못 한다.

3) Anna Levitina, Humans in Automated Decision-Making under the GDPR and AI Act (2024.12.) p.136.

한편 인간의 관리·감독을 구체적으로 어떻게 이행해야 하는지에 관해, GDPR과 AI Act는 각각의 방식으로 정보주체 및 이용자를 상호보완적으로 보호하고 있다. 자동화된 결정의 한 유형으로 개인정보의 분석에 기반해 개인의 특성을 평가하는 프로파일링(profiling)의 경우 GDPR에서는 오류를 시정하고 위험을 최소화할 수 있는 기술적·관리적 조치의 도입, 프로파일링에 적합한 수학적 또는 통계적 방법론의 적용 등 개인정보 보호를 위한 기술적 보호조치에 중점을 둔다. AI Act 역시 프로파일링을 고위험 AI 시스템으로 분류하고 있는데, 사업자가 취해야 하는 관리·감독 조치는 문제 발생시 적시에 인간의 개입이 가능하도록 인간과 인공지능 간 효과적인 인터페이스(human-machine interface)를 구축하고, AI 모델의 개발사업자인 제공자(providers)와 이용사업자인 배포자(deployers) 간 적절한 역할 분담에 따른 인간의 관리·감독 방안을 이용지침(instructions for use)에 명시해야 하는 등, GDPR에는 규정되어 있지 않은 새로운 사항들이다.⁴⁾ AI 모델의 개발사업자는 해당 모델의 성능·한계 및 학습데이터 등에 관해 상세히 이해하고 있지만 모델이 서비스로 구현되는 업권·환경이나 이용자의 특성을 정확히 파악하기 어렵고, 그 이용사업자는 서비스 구현 방식과 환경에 대한 이해도는 높으나 AI 모델 자체에 대한 정보에 한계가 있다는 점에서, 사전에 개발사업자가 이용사업자에게 제공하는 이용지침을 통해 인간의 관리·감독 방안을 적절히 분담하도록 하는 안전조치는 중요한 의미를 가진다.

3. 인공지능이 도출한 결과물에 대해 설명받을 권리(right to explanation)

■ 인공지능 제품 또는 서비스를 통해 인간에게 제공되는 결과물은 특정한 의사결정 또는 판단에 한정되지 않으며, 시장 동향에 대한 예측, 프로파일링에 기반한 맞춤형 상품의 추천, 동영상이나 광고 문구의 생성 등 그 유형이 매우 다양할 수 있다. 정보주체 또는 서비스 이용자의 알 권리 관점에서 기존의 IT 서비스와 인공지능 서비스 간의 가장 큰 차이점 중 하나는 블랙박스(Black Box) 속성으로 인해 인공지능이 제공하는 결과물이 어떤 정보나 근거에 기반하여 그 결과물을 도출했는지 쉽게 이해하기 어렵다는 점이다. 이 점에서 GDPR과 AI Act는 정보주체 또는 이용자의 설명받을 권리를 보장하고 있는데, 권리 보호 차원에서 양자는 충돌하기 보다는 상호보완적인 순기능을 할 것으로 기대된다. 두 법의 설명받을 권리는 설명의 대상과 수준이 대체로 유사한데, 완전 자동화된 결정에 대해서는 GDPR의 설명받을 권리가, 인간의 관리·감독이 요구되는 (즉, 완전 자동화된 결정이 내려지지 않는) 일정 영역의 고위험 AI 시스템에 대해서는 AI Act상의 설명받을 권리가 적용될 수 있기 때문이다.

GDPR상 자동화된 결정과 관련해 개인정보처리자(controllers)가 정보주체에 대해 설명해야 하는 대상은 해당 의사결정에 활용된 논리(logic) 및 의사결정으로 인해 예상되는 결과 및 그 중요성

4) 특히 생체정보에 기반한 개인 식별(biometric identification), 생체정보에 기반한 개인 분류(biometric categorization) 등 생체 정보를 활용하는 고위험 AI 시스템 유형에 대해서는 2인 이상의 인간에 의한 관리·감독을 의무화하고 있음.

이다. 개인정보처리자는 이러한 사항에 관한 “의미 있는 정보”(meaningful information)를 정보주체에게 전달해야 하는데, 이는 AI Act의 설명받을 권리에서도 유사한 문구로 규정하고 있어 실무적으로 그 해석이 중요할 것으로 보인다. 이와 관련하여 최근(2025.3.) EU 사법재판소(CJEU)은 GDPR의 해석에 관해 중요한 판결(Case C-203/22 (Dun & Bradstreet Austria))을 내린 바 있다.⁵⁾ 정보주체 입장에서 “의미 있는 정보”가 되기 위해서는 “간결하고 이해 가능한 설명”(concise and intelligible explanation)을 통해 전달되어야 하며, 알고리즘 등 복잡한 수학적 수식 또는 자동화된 결정이 내려지게 된 전 과정에 대한 상세한 설명 등은 그 기준에 미치지 못 한다고 재판부는 판시하였다. 다만 법원은 정보주체의 설명받을 권리는 제약 없이 행사될 수 있는 절대적 권리가 아니기에 개인정보처리자(사업자)의 영업비밀 보호 등 타인의 권리 보호와 개별 사안 별로 비교衡量되어야 한다는 점을 강조하였다. 즉 개인정보처리자가 영업비밀의 보호를 위해 설명받을 권리를 일방적으로 거부해서도 안 되지만, 정보주체 역시 설명받을 권리 행사를 이유로 영업비밀을 과도하게 요구할 수는 없다는 것이다. 적용대상은 일부 다르지만 유사한 권리행사에 대해 규정하고 있는 AI Act의 설명받을 권리 해석시에도 위 EU 사법재판소의 판례는 참고될 수 있을 것으로 보인다.

AI Act에서는 고위험 AI 시스템의 의사결정에 따라 법률적 효과 또는 이와 유사한 영향을 받는 이용자만 설명받을 권리를 갖게 되며, 설명의 주체는 고위험 인공지능 서비스를 운영하는 배포자이다. 설명의 대상은 의사결정 절차에서 AI 시스템이 수행하는 역할 및 해당 결정을 내리는데 고려된 주요 요소이며, 명확하고 의미 있는 설명(clear and meaningful explanation)이 전달되어야 한다. 다만 설명받을 권리가 보장되는 분야가 교육, 채용, 필수 공공·민간 서비스(일부 금융서비스 포함), 법 집행 등 제3부속서(Annex III)상 일부 고위험 영역에 한정되는 점, 설명 주체가 AI 모델에 대한 정보와 이해에 한계가 있는 배포자라는 점 등은 AI Act의 한계로 볼 수 있을 것이다.⁶⁾ 이용자가 자신의 권리를 행사하는데 있어 배포자의 기술적 이해가 제약으로 작용하지 않으려면, AI 모델의 개발 주체인 제공자가 배포자에게 의무적으로 제공하는 이용지침에 AI 모델의 결과물에 대한 기술적이고 합리적인 수준의 설명 방안이 충분한 수준으로 기재되어야 할 것으로 보인다. 한편, 타 EU법에서 이미 설명받을 권리를 규정하고 있는 사안의 경우 AI Act가 아닌 해당 법률에 따라 설명이 제공되는데, 자동화된 결정이 포함된 고위험 인공지능 서비스에 대해서는 두 법 간 설명 대상의 중첩이 문제될 수 있을 것이다. 앞서 언급한 바와 같이 GDPR은 의사결정에 활용된 논리 및 그 의사결정의 결과·중요성에 대해 설명받을 권리를 보장하고 있는데, AI Act의 설명 대상인 AI 시스템이 의사결정에서 어떤 역할을 수행했고 그 과정에서 어떤 주요 기준들이 고려되었는지는 GDPR의 설명 대상인 ‘의사결정에 활용된 논리’와 개념상 일정 부분 중복되어 GDPR이 우선 적용될 가능성도 있을 것으로 보인다.

5) Covington & Burling, CJEU Clarifies Rights on Automated-Decision-Making and Trade Secrets (2025.03.06.)

6) Nisevic, Cuypers & Bruyne, Explainable AI: Can the AI Act and the GDPR go out for a date? (2024.12.14.)

4. 영향평가

■ GDPR과 AI Act는 그 명칭은 다르지만 영향평가 제도를 두어 정보주체 또는 이용자의 권리 등에 미치는 위험과 영향을 평가하고 발생 가능한 권리 침해나 위험을 완화·해소하기 위한 조치를 사전에 검토하여 준비하도록 하는데 그 취지가 있다. GDPR에 따른 개인정보 영향평가(Data Protection Impact Assessment, DPIA)의 수행 주체는 개인정보처리자이며, AI상 기본권 영향평가(Fundamental Rights Impact Assessment, FRIA)를 실시해야 하는 주체는 배포자이다. 배포자는 이용자에게 직접 인공지능 서비스를 제공하는 접점에 있는 만큼 이용자의 기본권에 미치는 영향을 분석하고 그에 상응하는 대응조치를 마련하기에 적합한 지위에 있다고 볼 수 있을 것이다. AI 시스템의 제공자는 기본권 영향평가를 수행할 법적 의무는 없지만 AI의 개발 과정에서 영향도를 분석하기 위한 실무적 목적의 평가를 실시할 수 있는데, 영향평가의 중복 수행에 따른 불필요한 자원·비용의 소모 방지를 위해 배포자는 제공자로부터 전달받은 영향평가 결과로 자신의 의무를 갈음할 수 있다는 점을 참고할 수 있다.

두 법은 모든 적용 사안에 대해 영향평가를 의무화하고 있지는 않으며, 개인의 권리에 미치는 영향도가 큰 경우로 한정하여 영향평가를 의무적으로 실시해야 하는 경우를 법률에 구체적으로 명시하고 있다. GDPR은 정보처리에 신기술이 사용됨에 따라 개인의 권리·자유에 고위험을 초래할 가능성이 있는 경우 DPIA를 반드시 실시하도록 하고, 특히 그 우려가 큰 경우를 특정하여 DPIA 수행의 필요성을 강조한다. 개인에 대해 체계적이고 포괄적인 평가(systematic and extensive evaluation)를 내리는 자동화된 정보처리(프로파일링 포함)를 통해 정보주체에게 법적 또는 그와 유사한 효과를 미치는 경우, 민감정보 또는 범죄 관련 정보에 대한 대규모 처리를 수행하는 경우, 공공장소에서 대규모의 체계적 모니터링(CCTV 등)을 하는 경우가 이에 해당된다.⁷⁾ AI Act 역시 모든 고위험 AI 시스템에 대해 FRIA 수행이 요구되지는 않으며, 정부·공공기관, 공공 서비스를 제공하는 민간기관, 신용평가, 생명·건강보험에 있어 개인의 위험도 평가 및 요율 산정 등 일부 고위험 AI 시스템으로 그 대상이 한정된다. 단, 정부·공공기관, 공공 서비스를 제공하는 민간기관 중 전기, 난방, 가스, 수자원 등 핵심 인프라(critical infrastructure)에 사용되는 고위험 AI 시스템은 FRIA 의무 대상에서 제외된다.

앞서 언급한 바와 같이 AI Act는 GDPR의 DPIA를 통해 평가될 수 있는 사항에 대해 FRIA에서 번거롭게 재차 평가를 수행하는 면제하고 있는데, DPIA의 의무 대상이 추상적이면서 넓게 설정되어 공공 서비스와 일부 금융 서비스(신용평가, 보험 등)로 대상이 한정된 FRIA 의무 대상 상당 부분이 DPIA 대상에 포함될 수 있다는 점에 주목할 필요가 있다. 이 경우 두 종류의 영향평가를 완전히 별개로 실시하는 부담 없이 DPIA를 통해 영향평가의 상당 부분을 갈음하게 될 수 있을 것으로 보이는데, 구체적으로 어떤 내용이 DPIA로 해결될 수 있을 것인지는 향후 EU 인공지능청(AI

7) 개인정보보호위원회·한국인터넷진흥원, 우리 기업을 위한 2022 EU 일반개인정보보호법 가이드북 (2022.) p.177.

Office)에서 공개할 FRIA 양식(template)을 살펴보아야 할 것이다.⁸⁾

법률에서 확인할 수 있는 두 영향평가 항목 간의 공통점과 차이점은 다음과 같다. 우선 영향평가의 대상이 되는 정보처리 절차 또는 고위험 AI 시스템에 대한 상세한 기술(description) 및 위험 사항에 대한 대응방안을 작성하는 것은 두 영향평가 모두 공통점이다. 다만 대응방안 관련하여 DPIA에서는 개인정보를 보호하고 GDPR을 준수하기 위한 안전·보안 조치(safety and security measures)로만 포괄적으로 명시하고 있는 반면, FRIA는 내부 거버넌스, 민원 대응체계(complaint mechanism), 인간의 관리·감독 방안 등으로 요구되는 조치 유형을 세분화하고 있다는 점에서 차이를 보인다.⁹⁾ 또한 ‘위험’ 관련하여 개인정보 관련 리스크에 대한 영향을 중심으로 하는 DPIA에서는 정보처리의 성격·범위·내용·목적에 고려하여 개인에 미치는 위험에 대해서만 기술하도록 하고 있으나, 차별 금지, 생명권, 표현의 자유, 집회·결사의 자유 등 다양한 기본권에 미치는 영향을 종합적으로 검토하기 위한 목적의 FRIA는 구체적인 위험 유형 및 해당 AI 시스템의 사용에 따라 영향을 받게 되는 개인·집단을 구체적으로 분류하여 서술하도록 요구한다.¹⁰⁾ 마지막으로, DPIA와 달리 FRIA에서는 개별 AI 시스템의 예상 사용 기간 및 빈도에 대한 정보까지 영향평가 대상에 포함하고 있는데, 인공지능 서비스 이용 과정에서 사고 또는 문제 발생시 책임 소재 파악을 위한 추적가능성(traceability) 확보가 중요시되는 AI 시스템의 특성상 AI Act에서 개별 AI 시스템의 사용 시각·기간 등 로그(logs)를 기록으로 보존하도록 하는 것과 유사한 맥락으로 보인다.¹¹⁾

5. 법 집행기관: 개인정보 보호 정책과 AI 규제 정책 간의 조화

■ EU 집행위원회(European Commission, EC) 산하 인공지능청에 일임되어 있는 범용 AI(General-Purpose AI, GPAI) 규제를 제외하면 금지 대상 AI, 고위험 AI 등의 규제 집행권한은 각 회원국별로 지정되는 시장감독기관(market surveillance authority, MSA)에 맡겨져 있다.¹²⁾ 2024.8. 발효 후 규제 내용에 따라 순차적으로 이루어지는 AI Act의 시행시기에 따라 고위험 AI 시스템에 대한 규제는 2026.8.2.에 시행되는데, 법 집행기구 등 이를 위한 제도적 준비의 선행을 위해 각 회원국은 시행 1년 전인 2025.8.2.까지 자국 내 AI Act의 집행 소관기관인 MSA를 지정하여 집행위원회에 통지해야 한다. 국가별 규제 체계의 특성에 맞는 집행을 유연성 보장을 위해 AI Act는 MSA로 지정될 수 있는 부처·기관의 성격을 제한하지 않고 있을 뿐 아니라 분야별

8) EU AI Act 제27조 제5항은 배포자가 기본권 영향평가를 간소화된 방식으로 효과적으로 수행할 수 있도록 인공지능청이 자동화된 방식의 질의서 양식(template for a questionnaire through an automated tool)을 마련하도록 규정하고 있다.

9) Kezia Vilawa, Differences between Fundamental Rights Impact Assessment & Data Protection Impact Assessment (2024.07.30.)

10) Thomas Ajoodha & Jared Browne, Fundamental Rights Impact Assessments: What are they? How do they work? (2025.01.) p.1.

11) Kezia Vilawa, Differences between Fundamental Rights Impact Assessment & Data Protection Impact Assessment (2024.07.30.)

12) WilmerHale, Supervision and Enforcement of the European Union's AI Act (2024.12.17.)

로 복수의 MSA 지정도 허용하고 있는데, 복수의 MSA를 지정하는 경우 집행위원회와의 효과적인 소통을 위해 단일창구역할(single point of contact)을 할 MSA를 별도로 지정해야 한다. 아래에 소개하는 바와 같이, 현재까지 확인되는 MSA 지정 현황을 통해 나타나는 회원국별 다양성은 그 취지를 반영하고 있다.

일부 회원국은 AI Act의 집행을 전담할 기관을 신설하여 해당국 내 단일한 MSA로 지정하는 ‘중앙형 모델’(centralized model)을 선택하였다.¹³⁾ 그 대표적인 예인 스페인은 디지털전환부(Department of Digital Transformation) 산하에 2023년 신설된 ‘인공지능 감독청’(AI Supervisory Agency, AESIA)을 MSA로 지정하였다.¹⁴⁾ ‘AI 개발 및 안전 위원회’(Commission for the Development and Safety of AI)를 새로 설립하여 MSA로 지정하려는 폴란드, AI 정책과 집행을 담당할 ‘AI 위원회’(AI Commission)를 신설한 스웨덴 역시 중앙형 모델을 추구하는 입장으로 보인다.¹⁵⁾

이와 대조적으로 각 영역의 특성과 전문성을 중시하는 ‘분산형 모델’(decentralized model)을 추구하는 국가들은 복수의 MSA를 지정하는 방안을 지향한다. 핀란드의 경우 부처·기관 별 정책과 집행의 조율을 담당할 단일창구인 교통·통신청(Transport and Communications Agency, Traficom)을 중심으로, 디지털 인프라, 제품 안전, 의료, 금융, 교통 등을 담당하는 기존 정부기관들을 MSA로 지정하여 집행 권한을 분산하는 방향을 검토 중에 있는 것으로 알려졌다.¹⁶⁾¹⁷⁾

마지막으로, 회원국 차원의 AI Act 집행과 관련하여 의미 있는 시사점을 주는 부분은, 기본권 보호 정책과 법 집행에 있어 전문성이 부족할 수 있는 시장감독기관의 역할을 보완하기 위한 제도적 설계이다. 회원국 별로 기본권 보호 업무를 담당하는 부처·기관(authority protecting fundamental rights)은 제3부속서에 따른 고위험 AI 시스템과 관련해 AI Act에 따라 생성·보존되는 문서에 대한 접근을 업무 목적상 MSA에 요청할 권한이 있다. 나아가 해당 문서만으로는 특정 고위험 AI 시스템의 기본권 침해 우려에 대한 충분한 검토가 어렵다고 판단될 경우, 기본권 보호 소관 기관은 해당 AI 시스템의 기본권 침해 여부 판단을 위한 기술적 테스트를 MSA에 요청할 수 있으며, 그 테스트의 준비 과정에 긴밀히 관여할 수 있다. 앞서 분산형 모델을 추구하는 것으로 알려진 핀란드는 개인정보 보호 감독기관인 ‘데이터 보호 옴부즈맨’(Data Protection Ombudsman) 등 다수의 기본권 보호 기관이 MSA를 보완할 수 있도록 하여, AI의 개발·활용 과

13) EU AI Act Website, Overview of All AI Act National Implementation Plans (2025.05.19.)

14) EU AI Act Website, Overview of All AI Act National Implementation Plans (2025.05.19.)

15) Clyde & Co, Preparing for Enforcement: A Guide to the EU AI Act/ Market Surveillance Authorities (2025.05.13.)

16) 핀란드 정부는 2025.5.8. 이와 같은 내용의 EU AI Act에 대한 자국 감독기관 지정과 제재 규정을 담은 “특정 AI 시스템의 감독에 관한 법률” 제정안(Act on the Supervision of Certain AI Systems, Government Proposal 46/2025)을 의회에 제출하였는데, 동 법안의 최종 논의결과는 아직 확인되지 않음. (Hannes Snellman, EU AI Act - Latest Regulatory Developments in Finland (2025.05.13.))

17) Ministry of Economic Affairs and Employment of Finland, National Implementation of EU Artificial Intelligence

정에서 발생하는 기본권 침해의 방지라는 AI Act의 중요한 입법 목적을 실현하고자 하고 있다.¹⁸⁾

6. 나가며

■ 인공지능의 데이터 학습과 개발, 그리고 인공지능의 자동화된 결정 과정에서 피해를 입을 수 있는 이용자의 기본권에 대한 보호는, AI Act 뿐 아니라 기본권 중 개인정보와 프라이버시 보호에 특화되어 제정된 GDPR을 통해 상호보완적으로 해결해 나가야 할 사안이다. AI Act는 개인정보 보호를 위한 상세 내용을 규정하기 보다는 포괄적인 기본권 보호에 역점을 두고 있기에, 자동화된 결정, 설명받을 권리, 영향평가 등 두 법이 서로 만나는 영역에서 규범의 상충보다는 조화 속에 상호 간의 공백을 채워줄 수 있는 해석·적용이 필요하다. 고위험 AI 시스템 규제의 시행을 위한 AI Act의 하위법령과 가이드라인 제정이 2026.2.까지 완료될 예정인데, 곧 시행이 다가올 우리나라 인공지능 기본법과 개인정보 보호법 간의 조화와 상호보완적인 해석에 유용한 참고가 될 결과물이 나오기를 기대해 본다.

18) Ministry of Economic Affairs and Employment of Finland, National Implementation of EU Artificial Intelligence

참고 문헌 |

1. 이진규, 인공지능 프라이버시 침해위험 증가에 따른 국내외 관련 규범 (2024.01.)
2. Osborne Clarke, Interplay of the EU AI Act and GDPR (2025.03.25.)
3. Anna Levitina, Humans in Automated Decision-Making under the GDPR and AI Act (2024.12.)
4. Nisevic, Cuypers & Bruyne, Explainable AI: Can the AI Act and the GDPR go out for a date? (2024.12.14.)
5. Covington & Burling, CJEU Clarifies Rights on Automated-Decision-Making and Trade Secrets (2025.03.06.)
6. 개인정보보호위원회·한국인터넷진흥원, 우리 기업을 위한 2022 EU 일반개인정보보호법 가이드북 (2022.)
7. Kezia Vilawa, Differences between Fundamental Rights Impact Assessment & Data Protection Impact Assessment (2024.07.30.)
8. Thomas Ajoodha & Jared Browne, Fundamental Rights Impact Assessments: What are they? How do they work? (2025.01.)
9. WilmerHale, Supervision and Enforcement of the European Union's AI Act (2024.12.17.)
10. EU AI Act Website, Overview of All AI Act National Implementation Plans (2025.05.19.)
11. Clyde & Co, Preparing for Enforcement: A Guide to the EU AI Act/ Market Surveillance Authorities (2025.05.13.)
12. Hannes Snellman, EU AI Act - Latest Regulatory Developments in Finland (2025.05.13.)
13. Ministry of Economic Affairs and Employment of Finland, National Implementation of EU Artificial Intelligence

AI 시대 신기술·신산업 혁신 촉진을 위한 개인정보 규율체계 정비 방향

최경진

가천대학교 | 교수

1. 머리말

■ 세계는 지금 인공지능을 둘러싸고 글로벌 패권 경쟁을 벌이고 있다. 각국의 미래 경쟁력을 좌우하게 될 핵심 동력으로 인공지능에 주목하고 있다. 글로벌 인공지능 1등 선도국가인 미국은 풍부한 자원과 우수 인재, 선도적인 R&D 역량과 인프라 등 모든 면에서 압도적인 역량을 갖추고 있음에도, 지난 7월 23일 AI Action Plan¹⁹⁾을 발표하면서 글로벌 AI 패권을 더욱 공고히 하려는 강력한 의지와 구체적 실행계획을 천명하였다.

우리 정부도 인공지능 글로벌 3대 강국(AI G3)을 목표로 설정하고 다양한 정책방안을 마련하여 추진 중이다. 정책적 목표 중에는 세계 최고 수준의 거대언어모델 개발 추진이나 기존 산업의 AI 전환(AIX) 등이 포함되어 있는데, 반도체 개발이나 인프라 구축, 인재양성이나 세계 인재 유치 등도 중요하지만, 데이터 혁신은 그 못지 않게 중요하다. 거대언어모델의 개발을 위해서도 고품질의 데이터를 최대한 많이 확보하여 활용하는 것도 중요하지만, 기존 산업의 AIX를 가속화하기 위해서는 기존 산업으로부터 데이터를 생산하고 집적하여 AIX에 활용하는 것도 중요하기 때문이다.

대량의 고품질 데이터 없이는 인공지능 경쟁력 확보는 사실상 불가능하다. 그러나 양질의 데이터를 인공지능 혁신에 활용하기에는 저작권과의 충돌이나 개인정보 규제가 허들로 작용할 수 있다. 그동안 경제 발전에 중요한 역할을 해왔던 저작권을 무시할 수도 없고, 디지털 사회를 넘어 인공지능 사회로 전환됨에 따라 사람의 사적 영역의 의미는 더욱 커지고 있고 그에 따라 데이터 프라이버시나 개인정보의 보호에 대한 필요성도 증가하고 있다. 이 때문에 AI 혁신에 불가피한 데이터, 특히 저작물이나 개인정보에 대한 보다 자유로운 활용의 필요성과 기존 규제 사이의 조정을 어떻게 할 것인가는 AI 혁신을 성공으로 이끌기 위한 전제이자 핵심적인 문제가 되고 있다.

이하에서는 AI 혁신에 필요한 개인정보의 안전한 활용을 촉진하기 위한 법제도 개선의 기본방향과 함께 보다 구체적인 실천방안으로서 개인정보 원본의 안전한 활용을 위한 적법한 처리근거의 확충 및 특례 도입 방안과 개인정보보호법제의 경직성을 완화하고 보다 유연하지만 합리적인 개인정보규율체계를 정립하기 위한 개인정보보호법 개정방향을 제시하고자 한다.

19) 정식 명칭은 “Winning the AI Race: America’s AI Action Plan”이다. (Whitehouse, Winning the Race AMERICA’S AI ACTION PLAN (2025.01.))

2. 인공지능 혁신 시대에 맞는 개인정보 규율체계 정립 방향

■ 인공지능 혁신은 현 시대에 모두가 공감하는 시대적 가치이다. 그러나 인공지능이 모든 문제를 해결해줄 수 없을뿐만 아니라 인공지능 혁신이 모든 가치에 우선하는 것은 아니다. 특히 국민 개인의 개인정보에 대한 권리는 법이 보호해야 할 중요 대상이기때문에 양자가 적절히 균형을 가질 수 있도록 법제도를 정밀히 설계하는 것이 매우 중요하다. AI 시대는 데이터를 기반으로 한 기술 혁신을 통해 국가 경쟁력을 재편하고 있다. 이 과정에서 개인정보는 단순한 보호 대상이 아닌, 혁신의 자원이자 기본권의 핵심 요소로 떠오르고 있다. 이에 따라 인공지능 기술 발전과 국민의 프라이버시 보호를 동시에 실현할 수 있는 새로운 개인정보 규율체계의 정립이 필요하다.

첫째, 개인정보 규율은 혁신을 가로막는 장벽이 아닌, AI 활용을 가능케 하는 촉진자 역할을 해야 한다. 스타트업과 연구자가 안심하고 데이터를 활용할 수 있도록 예측 가능한 규제 환경을 조성하고, 개인정보보호위원회는 조사와 집행 단계에서도 산업과 기술의 맥락을 반영하여 ‘세이프하버’ 역할을 강화해야 한다. 동시에 국민에게는 신속하고 실질적인 피해구제를 제공하는 ‘세이프가드’로서 작동해야 한다.

둘째, 기존의 ‘수집·이용·제공’이라는 선형적 규율체계는 AI 기반의 동시다발적 데이터 처리 현실에 부합하지 않는다. AI 냉장고, 로봇청소기 등 스마트 기기는 정보의 수집과 제공이 실시간으로 결합된 형태로 작동하며, 이에 대응하기 위한 동적인 규율체계 설계가 필요하다. AI의 특성과 위험도를 고려한 차등적 규제 적용이 핵심이다. 나아가 AI 시대의 안전한 개인정보처리를 뒷받침할 수 있는 다양한 적법한 처리근거를 마련하거나 안전한 처리환경을 제도적으로 구축 및 지원해주어야 한다.

셋째, 개인정보보호위원회는 단순한 규제기관을 넘어 균형의 설계자이자 조정자로서의 역할을 강화해야 한다. 이를 위해 내부 조직의 전문성 확대와 함께 개인정보 정책 기획, 기술 연구, 국제 협력 등을 수행할 싱크탱크 기능이 필요하며, 국민 체감형 권익 증진을 위한 통합센터 및 지역 기반 지원체계도 구축되어야 한다. 과징금을 기반으로 한 ‘개인정보보호기금’은 피해자 구제, 프라이버시 기술 지원, 취약계층 보호 등에 활용되어야 한다.

넷째, 개인정보 보호와 AI 혁신은 충돌하는 개념이 아니다. 헌법 제17조의 사생활 보호와 제127조의 과학기술 진흥은 상호 보완적 가치로, 데이터 주권과 기술 경쟁력을 동시에 확보할 수 있는 정합적 해석이 필요하다. 글로벌 규범과의 조화도 중요하다. 데이터 보호주의와 자유주의 사이에서 대한민국은 전략적 유연성을 갖춘 개인정보 거버넌스를 구축해야 하며, 이는 인공지능 시대를 선도하기 위한 국가적 인프라가 되어야 한다.

궁극적으로 인공지능 혁신 시대의 개인정보 규율체계는 ‘혁신과 보호’라는 두 목표를 조화롭게 실현하는 방향으로 나아가야 하며, 이는 지속가능한 디지털 사회로의 전환을 위한 핵심 기반이 될 것이다.

3. 인공지능 혁신 시대 안전한 개인정보처리를 위한 개인정보보호법 개선방안

① 현재까지의 노력

인공지능 혁신을 뒷받침하기 위하여 지금까지 개인정보보호법 해석 측면에서 정책적 가이드 발간을 통한 개선의 노력과 함께 개인정보보호법 개정이라는 입법적 노력이 진행되어 왔다. 개인정보의 추가적 이용·제공을 규정한 개인정보보호법 제15조 제3항 및 제17조 제4항의 해석과 관련하여 “인터넷 쇼핑몰에 가입한 회원을 대상으로 당초 수집 목적인 쇼핑몰 이용과 관련하여 고객 A/S를 효율적으로 제공하기 위해 회원이 예측 가능한 범위 내에서 상담서비스를 제공하는 경우에는 법 제15조 제3항의 요건을 충족한 후 당초 수집한 개인정보를 추가적으로 AI 챗봇 기능 개선 및 상담을 위해 이용할 수 있음”²⁰⁾이라고 해석하거나 개인정보보호법 제15조제1항제6호에 규정된 정당한 이익 조항을 근거로 개인정보처리자의 정당한 이익이 있을 것, 개인정보 처리가 정당한 이익의 달성을 위하여 필요하고 상당한 관련성 및 합리성이 인정될 것, 개인정보처리자의 정당한 이익이 명백하게 정보주체의 권리보다 우선할 것의 요건을 판단기준으로 설정하여 공개된 개인정보 처리를 인공지능 개발 목적으로 활용할 수 있게 안내서²¹⁾를 제시하는 등 다각적 노력을 해왔다.

입법적 노력 측면에서는 인공지능(AI) 기술을 개발하거나 성능을 개선하기 위해 필요한 경우에는 강화된 안전조치 및 정보주체의 권리 보장 방안 등을 마련하여 개인정보보호위원회의 심의·의결을 거친 때에는 인공지능(AI) 등 기술 개발 및 성능 개선을 위해 적법하게 수집한 개인정보를 활용할 수 있도록 하고, 민감정보 등의 처리로 인해 정보주체의 권리 또는 이익에 중대한 영향을 미치거나 위험 우려가 있는 경우에는 위험요인 평가를 하도록 하며, 개인정보 보호위원회의 동일·유사한 심의·의결이 있었던 경우 등에는 심의·의결 절차를 간소화할 수 있도록 하되 심의·의결한 주요 내용을 인터넷 홈페이지에 공개하도록 하는 한편, 개인정보 보호위원회가 주기적으로 이행 점검 등 엄격한 관리·감독을 하도록 하여 개인정보가 안전하게 처리되도록 하려는 개인정보보호법 개정안²²⁾²³⁾이나 정보주체가 스스로 사회관계망서비스 등에 직접 또는 제3자를 통하여 공개한 개인정보에 대해서는 정보주체의 동의 없이 수집할 수 있도록 하되, 그 범위는 해당 정보주체의 동의가 있었다고 객관적으로 인정되는 범위 내로 한정하도록 함으로써 인공지능 기술의 발전에 따른 법 적

20) 개인정보보호위원회, 개인정보 처리 통합 안내서 (2025.07) 81p.

21) 개인정보보호위원회, 인공지능(AI) 개발·서비스를 위한 공개된 개인정보 처리 안내서 (2024.07.)

22) 고동진, 대표발의안(의안번호 2208904) (2025.03.13.)

23) 민병덕, 대표발의안(의안번호 2207858) (2025.01.31.)

용의 모호함을 해소하고, 정보주체의 권리보호와 인공지능 기술 발전 간의 균형을 도모하고자 한 개인정보보호법 개정안²⁴⁾ 등이 있다.

이상과 같은 노력이 있었지만, 정책 가이드만으로는 법적 불확실성을 제거할 수 없다는 한계가 지적되었고 관련 입법안에 대한 논의도 충분히 이루어지지 않고 있어서 인공지능 개발을 위한 대규모 데이터 학습에 개인정보를 안심하고 안전하게 처리될 수 있도록 하기 위한 충분한 제도적 환경을 구축하지 못하고 있다고 평가받고 있다.

② 개인정보의 적법한 처리근거 통합·일원화

인공지능 시대에도 개인정보보호는 지켜져야 할 기본적 가치이다. 개인정보 보호 체계는 더욱 정교하게 유지되어야 하며, 단순한 규제가 아닌 ‘동적인 개념’으로서의 활용과 보호의 균형점을 끊임없이 찾아야 한다. 이는 고정된 원칙이 아니라, 기술·맥락·사건별로 유연하게 적용되어야 하며, 그런 점에서 개인정보 거버넌스는 이 균형을 설계하고 실행하는 핵심적인 구조로 작동해야 한다. 그러나 지금의 개인정보 보호 법제는 이러한 전환기에 충분히 대응하지 못하고 있다. 현행 개인정보 규율체계는 ‘수집-이용-제공’이라는 선형적 흐름을 전제로 분절적으로 구성돼 있으나, AI 기반의 데이터 활용은 수집과 이용, 제3자 제공과 위탁이 복합적으로 동시에 일어난다. 예를 들어, AI 냉장고가 내부 재고를 스스로 판단해 식료품을 주문하는 과정에서는, 이용자의 로그인정보, 건강정보, 위치정보, 결제 정보까지도 외부 플랫폼과 자동으로 연계될 수밖에 없다. 이를 기존의 단절된 규제 틀로 관리하는 것은 비효율적이며, 결국 기술의 발전을 따라가지 못하는 결과를 낳는다. 개인정보 규율체계의 근간이라고 할 수도 있는 개인정보 적법한 처리근거를 규정한 제15조와 제17조를 통합하고 제18조 등 적법한 처리근거를 다루는 규정들을 정비해 나가야 한다.

③ 인공지능 학습을 위한 개인정보처리 특례 도입

인공지능 기술 개발을 위한 개인정보처리 특례를 규정한 개인정보보호법 개정안이 현재 국회에 발의되어 있다. 이에 의하면, 개인정보처리자는 개인정보보호법 또는 다른 법령에 따라 적법하게 수집한 개인정보를 개인정보보호법 제3장의 규정에도 불구하고 인공지능 기술 개발(성능 개선을 포함)을 위하여 당초 수집한 목적 외로 처리할 수 있게 된다(개정안 제28조의12 제1항). 다만, ① 영상, 음성, 이미지, 부호 및 문자 등 처리되는 정보의 특성, 인공지능 기술 개발과의 관련성 등을 고려하였을 때 익명 또는 가명으로 처리하여서는 인공지능 기술 개발이 어려운 경우, ② 개인정보의 안전한 처리를 위한 기술적·관리적·물리적 조치가 된 공간에서 처리하는 등 대통령령으로 정하는 기준에 따른 안전장치를 마련한 경우, ③ 인공지능 기술 개발의 목적이 공공의 이익 증진을 목적으로

24) 김태선, 대표발의안(의안번호 2208067) (2025.02.11.)

로 하는 경우 또는 정보주체 또는 제3자의 이익을 보호하거나 인공지능 기술 혁신을 촉진하는 등 사회적 이익 증진을 목적으로 하는 경우 중 어느 하나를 포함하고 있는 경우로서 정보주체 또는 제3자의 이익을 부당하게 침해할 우려가 현저히 낮은 경우이어야 한다. 또한 절차적 통제로서 개인정보처리자는 이에 따라 개인정보를 처리하려는 경우에는 각 요건에 해당하는지 여부에 대하여 개인정보보호위원회의 심의·의결을 받아야 하며, 개인정보보호위원회는 정보주체의 권리 보장, 개인정보의 안전한 처리를 위하여 필요한 범위에서 조건을 붙일 수 있도록 규정한다(개정안 제28조의12 제2항). 또한 개인정보보호위원회는 민감정보 등의 처리로 인하여 정보주체의 권리 또는 이익에 중대한 영향을 미치거나 위험을 초래할 우려가 있는 경우로서 대통령령으로 정하는 기준에 해당하는 경우에는 해당 개인정보처리자에게 기간을 정하여 개인정보 처리로 인한 위험요인 분석과 개선사항 도출을 위한 평가를 하고 그 결과를 제출하도록 할 수 있다(개정안 제28조의12 제3항).

이러한 개정안에 대해서는 인공지능 혁신을 위하여 절차적 및 실체적 요건이 너무 까다롭거나 불확정 개념으로 예측가능성이 낮다는 비판도 가능하지만, 다른 한편으로는 특례에 따른 개인정보 처리의 시간적·물적 한계를 명확히 설정하지 않아서 인공지능이라는 기술만 활용하면 혁신적이지 않은 인공지능 R&D까지도 개인정보를 폭넓게 처리할 수 있게 될 수도 있다는 비판도 가능하다. 인공지능 혁신을 명확히 뒷받침할 수 있으면서 정보주체의 이익이 실질적으로 보장받을 수 있도록 충분한 논의를 하되 신속하게 특례를 도입하는 노력이 필요하다. 한편, 특례를 개인정보보호법에 규정하는 방안도 가능하지만, “특례”의 속성을 고려할 때 별도의 입법을 추진하거나 인공지능 혁신을 과감하게 지원해야 하는 시의성을 고려할 때 한시법으로서 AI 개인정보 처리 특례를 포함한 인공지능 혁신 지원을 위한 일괄적인 특례법을 제정하는 것도 고려할 필요가 있다.

④ 개인정보처리를 둘러싼 인공지능 혁신과 정보주체의 보호 사이의 합리적 조화를 위한 이익형량 규정의 도입

개인정보보호법의 엄격성과 경직성은 인공지능 발전뿐만 아니라 사회의 건전한 발전에도 장애가 될 수 있기 때문에 개인정보보호법의 합리적 유연성을 보장하기 위하여 개별적인 개인정보처리 상황에서 맥락과 사회적 수용성을 고려하여 처리의 합법성을 판단할 수 있도록 일반적 이익형량 규정의 도입이 필요하다. 이미 ‘정당한 이익’을 근거로 한 공개된 개인정보의 활용에 관한 개인정보보호위원회의 안내서도 공개되어 있지만, 정당한 이익 요건은 수집 목적과 강하게 결합되어 있는 한 인공지능 개발을 위하여 개인정보 원본을 학습용 데이터로 활용하는 것은 당초 수집 목적 외로 판단될 여지가 크기 때문에 인공지능 시대에 개인정보 처리의 전체 라이프 사이클에서 합리적 유연성을 보장하기 위한 맥락 기반의 개별적 판단이 보장되지 않는다. 따라서 인공지능 혁신뿐만 아니라 우리 사회의 운영 과정에서 끊임없이 처리되는 개인정보를 둘러싼 합리적인 법적 판단을 위하여 일반적 이익형량 규정의 도입을 적극 검토해보아야 한다.

최근 대법원은 개인정보처리의 합법성 판단 시에 일반 규정인 형법 상 ‘정당행위’ 규정을 적용

하여 판단한 사례가 있다. 즉, “사회상규에 위배되지 않는 행위에 해당하여 형법 제20조에 따라 위법성이 조각될 수 있다. 이때 정당행위에 해당하는지 여부는 개인정보 제출자가 개인정보를 수집·보유하고 제출하게 된 경위 및 목적, 개인정보를 제출한 상대방, 제출 행위의 목적 달성에 필요한 최소한의 정보 제출인지 여부, 비실명화 등 개인정보의 안전성 확보에 필요한 조치 가능성 및 조치 여부와 내용, 제출한 개인정보의 내용, 성질(민감정보 여부 등) 및 양, 침해되는 정보주체의 법익 내용, 성질 및 침해의 정도, 개인정보를 제출할 다른 수단이나 방식의 존재 여부, 다른 수단이나 방식을 취하지 않고 개인정보를 제출하게 된 불가피한 사정의 유무 등 개별적인 사안에서 나타난 여러 사정을 종합적으로 고려하여 객관적이고 합리적으로 판단하여야 한다”²⁵⁾고 판시하였다. 그러나 개인정보보호법은 민사책임, 행정규제, 형사책임이 혼재되어 있기 때문에 개인정보보호법 상 책임 전반에 적용될 수 있는 일원화된 일반적 이익형량 규정을 도입할 필요가 있다.²⁶⁾²⁷⁾

4. 맺음말

■ 인공지능은 단순한 기술 진보를 넘어 사회 전반의 구조를 변화시키는 대전환의 핵심 동력이다. 이 혁신의 물결을 국가 경쟁력으로 연결하기 위해서는 고품질 데이터의 적극적 활용이 필수적이며, 특히 개인정보의 활용 가능성과 보호 필요성 사이의 균형은 그 어느 때보다 중요해지고 있다.

지금까지 정부는 인공지능 시대에 대응하기 위한 다양한 해석상·입법상 노력을 전개해 왔지만, 기술의 발전 속도에 비해 규제 체계는 여전히 경직되고, 불확실성이 해소되지 않은 채로 남아 있다. 개인정보보호법의 개정 방향은 이러한 한계를 극복하고, 개인정보의 안전한 활용과 정보주체의 권리 보호를 동시에 구현할 수 있는 구조로 나아가야 한다.

앞으로의 법제도는 기술 중립성과 맥락 적합성을 기반으로, 인공지능 시대의 복합적 데이터 활용 현실에 부합하는 ‘동적이고 유연한 규율체계’를 구축해야 한다. 적법한 처리근거의 통합, 인공지능 학습 목적의 특례 도입, 이익형량 기반의 개별적 판단 체계 마련은 그러한 체계 전환의 핵심이 될 것이다. 특히 개인정보보호위원회는 단순한 규제자에 머무르지 않고, 균형의 설계자이자 국가 경쟁력의 전략 거버넌스로서 기능해야 하며, 민간의 AI 활용과 국민의 기본권 보호라는 두 축을 동시에 견인해나가야 한다.

궁극적으로, 인공지능 혁신과 개인정보 보호는 양립할 수 없는 가치가 아니라 조화와 균형 속에서 함께 발전할 수 있는 공동의 목표다. 대한민국이 AI 선도국가로 도약하기 위해서는, 개인정보를

25) 대법원, 2023도3673 판결 (2025.07.18.)

26) 최경진 외 12인, 개인정보보호법 (2024.) 40p.

27) 최경진, “개인정보 보호 관련법의 해석에 있어서 이익형량론과 일반적 이익형량론 규정의 필요성에 관한 고찰” (2017.) 115-117p.

단절과 통제의 대상으로만 보는 낡은 시각을 넘어, 책임 있는 활용을 전제로 한 '안전한 개방과 혁신의 법제도'를 구축해 나가야 한다. 이러한 방향 전환이야말로 인공지능 시대를 선도하는 디지털 국가로서 대한민국이 나아갈 미래의 기반이 될 것이다.

참고 문헌 |

1. Whitehouse, Winning the Race AMERICA'S AI ACTION PLAN (2025.01.)
2. 개인정보보호위원회, 개인정보 처리 통합 안내서 (2025.07)
3. 개인정보보호위원회, 인공지능(AI) 개발·서비스를 위한 공개된 개인정보 처리 안내서 (2024.07.)
4. 고동진, 대표발의안(의안번호 2208904) (2025.03.13.)
5. 민병덕, 대표발의안(의안번호 2207858) (2025.01.31.)
6. 김태선, 대표발의안(의안번호 2208067) (2025.02.11.)
7. 대법원, 2023도3673 판결 (2025.07.18.)
8. 최경진 외 12인, 개인정보보호법 (2024.)
9. 최경진, “개인정보 보호 관련법의 해석에 있어서 이익형량론과 일반적 이익형량론 규정의 필요성에 관한 고찰” (2017.)

PRIVACY REPORT

개인정보 이슈 심층분석

「2025 개인정보 이슈 심층분석 보고서」는
개인정보보호위원회의 출연금으로 수행한 사업의 결과물입니다.

한국인터넷진흥원의 승인 없이 본 보고서의 무단전재나 복제를 금하며,
인용 출처 「2025 개인정보 이슈 심층분석 보고서」를 밝혀주시기 바랍니다.

본 보고서의 내용은
한국인터넷진흥원의 공식 견해가 아님을 알려드립니다.